

Поиск уязвимостей

Александр Дорофеев, CISSP, CISA, CISM

Echelon Eyes



@ECHELONEYES

Записи и презентации будут опубликованы в телеграм-канале Echelon Eyes

<https://t.me/EchelonEyes>

Предупреждение

- Рассматриваемые в курсе приемы тестирования защищенности можно отрабатывать только в собственной виртуальной лаборатории в отношении тестовых машин.
- Использование приемов в отношении реальных информационных ресурсов может подпадать под одну из следующих статей УК РФ:
 - УК РФ Статья 272. Неправомерный доступ к компьютерной информации
 - УК РФ Статья 273. Создание, использование и распространение вредоносных компьютерных программ
 - УК РФ Статья 274.1. Неправомерное воздействие на критическую информационную инфраструктуру Российской Федерации
 - УК РФ Статья 274. Нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации и информационно-телекоммуникационных сетей



Домашнее задание 2

1. Определить версии сетевых сервисов с помощью NMAP в Metasploitable 2.
2. Найти директории на web-серверах, запущенных на Metasploitable 2.
3. Определить имя и адрес почтового сервера учебного центра «Эшелон».

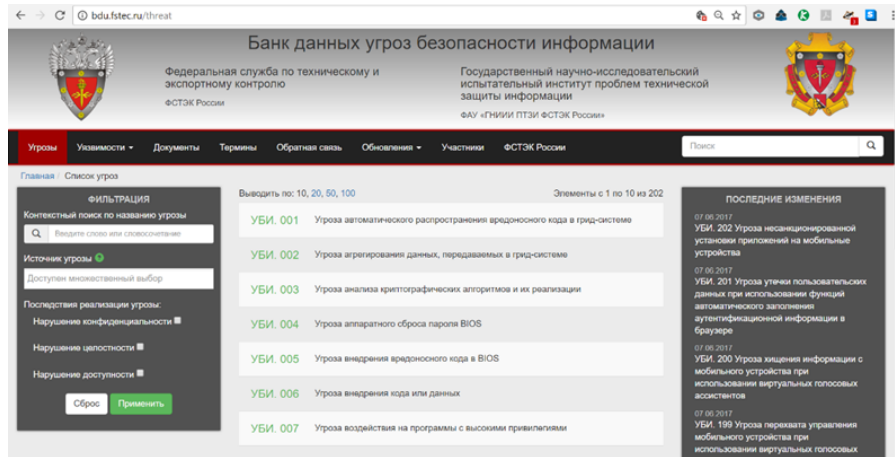
План

1. Определения
2. Базы данных уязвимостей
3. Подходы к поиску уязвимостей нулевого дня и известных
4. Ручной поиск уязвимостей
5. Традиционные подходы к поиску уязвимостей с помощью сканеров безопасности
6. Поиск уязвимостей с помощью Сканер-ВС 6

Определения из ГОСТ Р 56546-2015

- **уязвимость:** недостаток (слабость) программного (программно-технического) средства или информационной системы в целом, который(ая) может быть использован(а) для реализации угроз безопасности информации.
- **уязвимость кода:** уязвимость, появившаяся в процессе разработки программного обеспечения.
- **уязвимость конфигурации:** уязвимость, появившаяся в процессе задания конфигурации (применения параметров настройки) программного обеспечения и технических средств информационной системы.
- **уязвимость архитектуры:** уязвимость, появившаяся в процессе проектирования информационной системы.
- **степень опасности уязвимости:** мера (сравнительная величина), характеризующая подверженность информационной системы уязвимости и ее влияние на нарушение свойств безопасности информации (конфиденциальность, целостность, доступность).

Уязвимости: известные и нулевого дня



Банк данных угроз ФСТЭК России



Нулевого дня (zero day)

Степень опасности уязвимости

- Common Vulnerability Scoring System (CVSS) — это открытый стандарт, используемый для расчета количественной оценки степени опасности.
- При расчете учитываются такие факторы, как наличие эксплойта, возможность удаленной эксплуатации, необходимость авторизации, возможные последствия.
- Калькуляторы для расчета CVSS 2/3/3.1:
<https://bdu.fstec.ru/calc>

Пример: Opera DLL search order hijacking (CVE-2018-18913)

CVSS v3.1 Base Score: 7.8

Метрика	Значение	Комментарии
Attack Vector	Local	Атакующий должен получить локальный доступ к машине либо напрямую, либо с помощью методов социальной инженерии, чтобы загрузить вредоносную DLL.
Attack Complexity	Low	Атака легко воспроизводится.
Privileges Required	None	Специальных привилегий атакующему не требуется.
User Interaction	Required	Требуется взаимодействие с жертвой для запуска вредоносной DLL.
Scope	Unchanged	Уязвимый компонент.
Confidentiality	High	Позволяет атакующему захватить полный контроль над системой
Integrity	High	Позволяет атакующему захватить полный контроль над системой
Availability	High	Позволяет атакующему захватить полный контроль над системой

Определение степени опасности уязвимости

- CVSSv2:
 - Низкая (Low) – 0.0 – 3.9
 - Средняя (Medium) – 4.0 – 6.9
 - Высокая (High) – 7.0 – 10.0
- CVSSv3:
 - Не определен (None) – 0.0
 - Низкая (Low) – 0.1 – 3.9
 - Средняя (Medium) – 4.0 – 6.9
 - Высокая (High) 7.0 – 8.9
 - Критическая (Critical) – 9.0 – 10.0



Упрощенно:

- Низкая – получение информации о системе
- Средняя – получение информации о системе, которая будет полезна для проведения дальнейшей атаки, либо уязвимость, которую очень сложно проэксплуатировать.
- Высокая и критическая – получение административного доступа, либо запуск произвольного кода.

CWE

- CWE (Common Weakness Enumeration) – перечень типов дефектов программного и аппаратного обеспечения.
- <https://cwe.mitre.org/>

Тип ошибки Недостаточная проверка вводимых данных

Идентификатор **CWE-20**
типа ошибки ?

699 - Software Development

- ⊕ **C** API / Function Errors - (1228)
- ⊕ **C** Audit / Logging Errors - (1210)
- ⊕ **C** Authentication Errors - (1211)
- ⊕ **C** Authorization Errors - (1212)
- ⊕ **C** Bad Coding Practices - (1006)
- ⊕ **C** Behavioral Problems - (438)
- ⊕ **C** Business Logic Errors - (840)
- ⊕ **C** Communication Channel Errors - (417)
- ⊕ **C** Complexity Issues - (1226)
- ⊕ **C** Concurrency Issues - (557)
- ⊕ **C** Credentials Management Errors - (255)
- ⊕ **C** Cryptographic Issues - (310)
- ⊕ **C** Key Management Errors - (320)
- ⊕ **C** Data Integrity Issues - (1214)
- ⊕ **C** Data Processing Errors - (19)
- ⊕ **C** Data Neutralization Issues - (137)
- ⊕ **C** Documentation Issues - (1225)
- ⊕ **C** File Handling Issues - (1219)
- ⊕ **C** Encapsulation Issues - (1227)
- ⊕ **C** Error Conditions, Return Values, Status Codes - (389)
- ⊕ **C** Expression Issues - (569)
- ⊕ **C** Handler Errors - (429)
- ⊕ **C** Information Management Errors - (199)
- ⊕ **C** Initialization and Cleanup Errors - (452)
- ⊕ **C** Data Validation Issues - (1215)
- ⊕ **C** Lockout Mechanism Errors - (1216)
- ⊕ **C** Memory Buffer Errors - (1218)
- ⊕ **C** Numeric Errors - (189)
- ⊕ **C** Permission Issues - (275)
- ⊕ **C** Pointer Issues - (465)
- ⊕ **C** Privilege Issues - (265)
- ⊕ **C** Random Number Issues - (1213)
- ⊕ **C** Resource Locking Problems - (411)
- ⊕ **C** Resource Management Errors - (399)
- ⊕ **C** Signal Errors - (387)
- ⊕ **C** State Issues - (371)
- ⊕ **C** String Errors - (133)
- ⊕ **C** Type Errors - (136)
- ⊕ **C** User Interface Security Issues - (355)
- ⊕ **C** User Session Errors - (1217)

CVE

- CVE (Common Vulnerabilities and Exposures) — база данных общеизвестных уязвимостей информационной безопасности. Каждой уязвимости присваивается идентификационный номер вида CVE-год-номер, описание и ряд общедоступных ссылок с описанием.

- <https://www.cve.org/>

← → ↻ cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523

CVE-ID	
CVE-2011-2523	Learn more at National Vulnerability Database (NVD) • CVSS Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings • CPE Information
Description	
vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.	
References	
Note: References are provided for the convenience of the reader to help distinguish between vulnerabilities. The list is not intended to be complete.	
- MISC:http://packetstormsecurity.com/files/162145/vsftpd-2.3.4-Backdoor-Command-Execution.html - MISC:https://access.redhat.com/security/cve/cve-2011-2523 - MISC:https://packetstormsecurity.com/files/102745/Vsftpd-2.3.4-Backdoor-Command-Execution.html - MISC:https://security-tracker.debian.org/tracker/CVE-2011-2523 - MISC:https://vigilance.fr/vulnerability/vsftpd-backdoor-in-version-2-3-4-10805 - MLIST:[oss-security] 20110711 Re: vsftpd download backdoored - URL:https://www.openwall.com/lists/oss-security/2011/07/11/5	
Assigning CNA	
Red Hat, Inc.	
Date Record Created	
20110615	Disclaimer: The record creation date may reflect when the CVE ID was allocated or reserved, and does not necessarily reflect when the CVE was updated in CVE.
Phase (Legacy)	
Assigned (20110615)	
Votes (Legacy)	
Comments (Legacy)	
Proposed (Legacy)	
N/A	
This is a record on the CVE List , which provides common identifiers for publicly known cybersecurity vulnerabilities.	
SEARCH CVE USING KEYWORDS: Submit You can also search by reference using the CVE Reference Maps .	
For More Information: CVE Request Web Form (select "Other" from dropdown)	

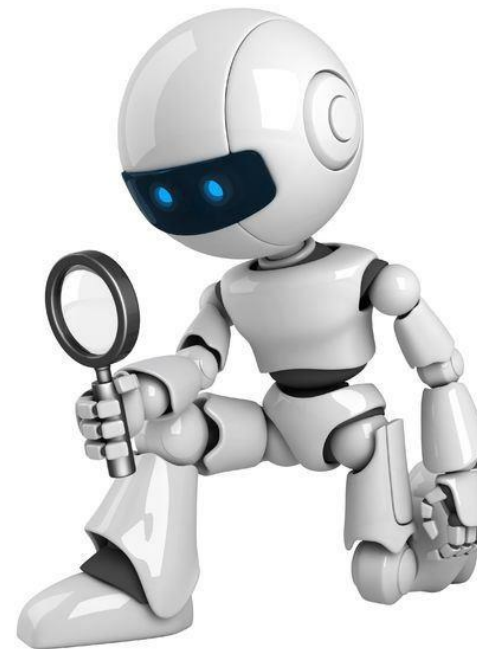
Базы данных уязвимостей

- БДУ ФСТЭК России: <https://bdu.fstec.ru/>
- NIST NVD: <https://nvd.nist.gov/>
- Chinese National Vulnerability Database (CNNVD):
<https://www.cnvd.org.cn/>
- Debian GNU/Linux Security Bug Tracker
<https://security-tracker.debian.org/tracker/>
- Ubuntu CVE Tracker
<https://people.canonical.com/~ubuntu-security/cve/>
- RHEL/CentOS Security Data
<https://www.redhat.com/security/data/metrics/>

Поиск уязвимостей



Ручной



С помощью сканеров

Технология ручного поиска уязвимостей



Apache HTTP Server 2.2.8



apache http server 2.2.8 vulnerabilities

Поиск в Google

Мне повезёт!

Apache » Http Server » 2.2.8 : Security Vulnerabilities (Execute Code)

Cpe Name: cpe:/a:apache:http_server:2.2.8

CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9

Sort Results By: CVE Number Descending CVE Number Ascending CVSS Score Descending Number Of Exploits Descending

[Copy Results](#) [Download Results](#)

#	CVE ID	CWE ID	# of Exploits	Vulnerability Type(s)	Publish Date	Update Date	Score	Gained Access Level	Access	Complexity	Authentication	Conf.	Integ.	Avail.
1	CVE-2013-1862	310		Exec Code	2013-06-10	2017-09-18	5.1	None	Remote	High	Not required	Partial	Partial	Partial
mod_rewrite.c in the mod_rewrite module in the Apache HTTP Server 2.2.x before 2.2.25 writes data to a log file without sanitizing non-printable characters, which might allow remote attackers to execute arbitrary commands via an HTTP request containing an escape sequence for a terminal emulator.														
2	CVE-2010-0425			Exec Code	2010-03-05	2018-10-30	10.0	None	Remote	Low	Not required	Complete	Complete	Complete
modules/arch/win32/mod_isapi.c in mod_isapi in the Apache HTTP Server 2.0.37 through 2.0.63, 2.2.0 through 2.2.14, and 2.3.x before 2.3.7, when running on Windows, does not ensure that request processing is complete before calling isapi_unload for an ISAPI .dll module, which allows remote attackers to execute arbitrary code via unspecified vectors related to a crafted request, a reset packet, and "orphaned callback pointers."														

Total number of vulnerabilities : 2 Page : 1 (This Page)

Как можно узнать версию продукта?

- Если имеем дело с вежливым сетевым сервисом, то по из приветственного баннера.
- Если имеем дело с прикладным ПО, то из реестра, свойств файла, системы управления пакетами.
- Иногда можно вычислить, применив аналитические методы.

Еще источники информации о версиях ПО

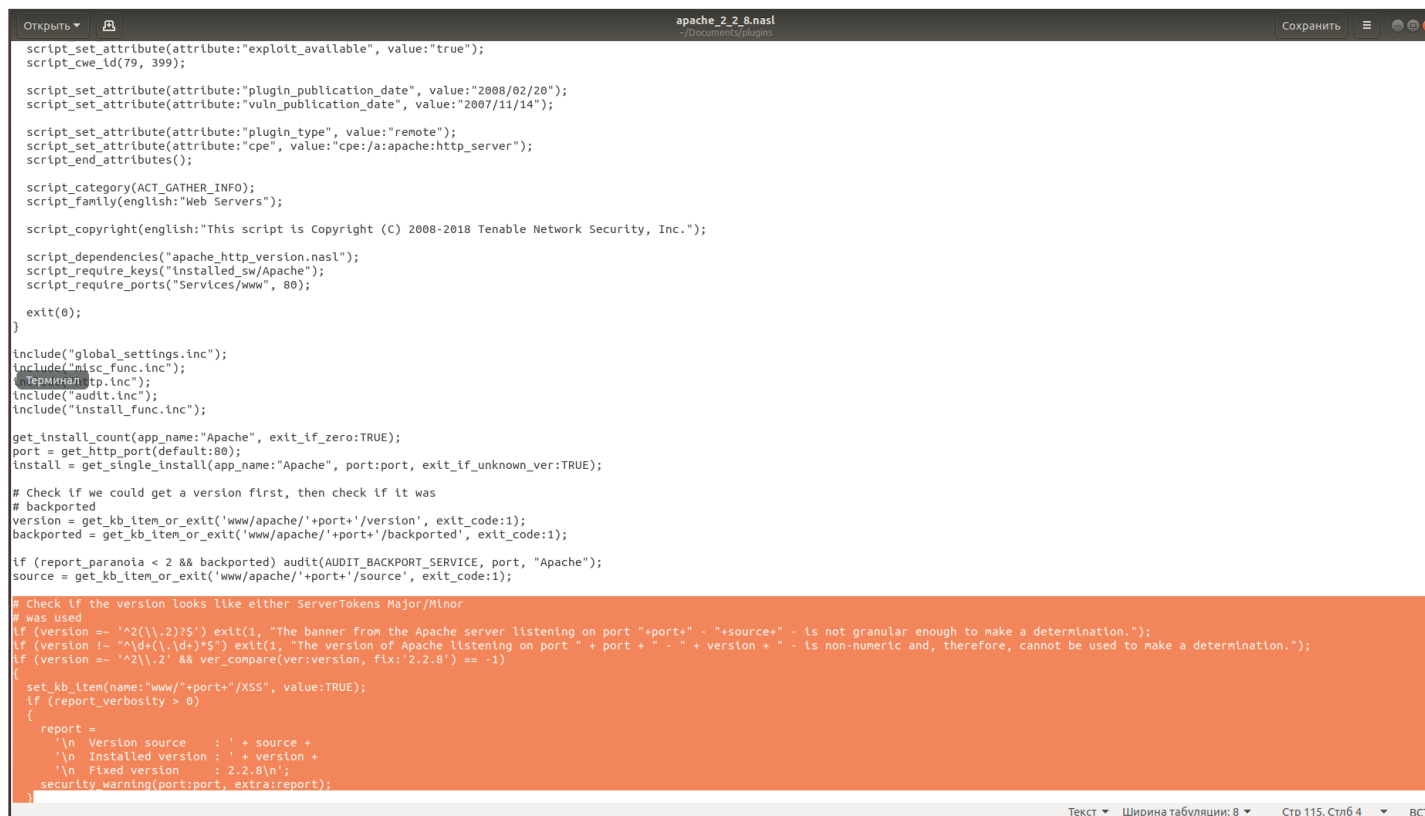
- HTTP-заголовки. Специальные плагины для браузеров для извлечения данных из HTTP-заголовков. Online-сервисы: <http://www.netcraft.com/>
- Информация на web-странице. Например, прямое упоминание версии.
- Оставленные страницы с данными конфигурации, например phpinfo.php
- Сообщения об ошибках систем
- Пресс-релизы вендоров и интеграторов (сопоставление даты новости с актуальной версией)
- Резюме ИТ-специалистов на страницах в сетях Linkedin, Мой Круг.

Применение сканеров уязвимостей

Традиционный подход: запуск скрипта для проверки

Nessus Attack
Scripting Language

Nmap Scripting Engine



```
Открыть  apache_2_2_8.nasl  Сохранить
~/Documents/plugins

script_set_attribute(attribute:"exploit_available", value:"true");
script_cwe_id(79, 399);

script_set_attribute(attribute:"plugin_publication_date", value:"2008/02/20");
script_set_attribute(attribute:"vuln_publication_date", value:"2007/11/14");

script_set_attribute(attribute:"plugin_type", value:"remote");
script_set_attribute(attribute:"cpe", value:"cpe:/a:apache:http_server");
script_end_attributes();

script_category(ACT_GATHER_INFO);
script_family(english:"Web Servers");

script_copyright(english:"This script is Copyright (C) 2008-2018 Tenable Network Security, Inc.");

script_dependencies("apache_http_version.nasl");
script_require_keys("installed_sw/Apache");
script_require_ports("Services/www", 80);

exit(0);
}

include("global_settings.inc");
include("misc_func.inc");
include("report.inc");
include("audit.inc");
include("install_func.inc");

get_install_count(app_name:"Apache", exit_if_zero:TRUE);
port = get_http_port(default:80);
install = get_single_install(app_name:"Apache", port:port, exit_if_unknown_ver:TRUE);

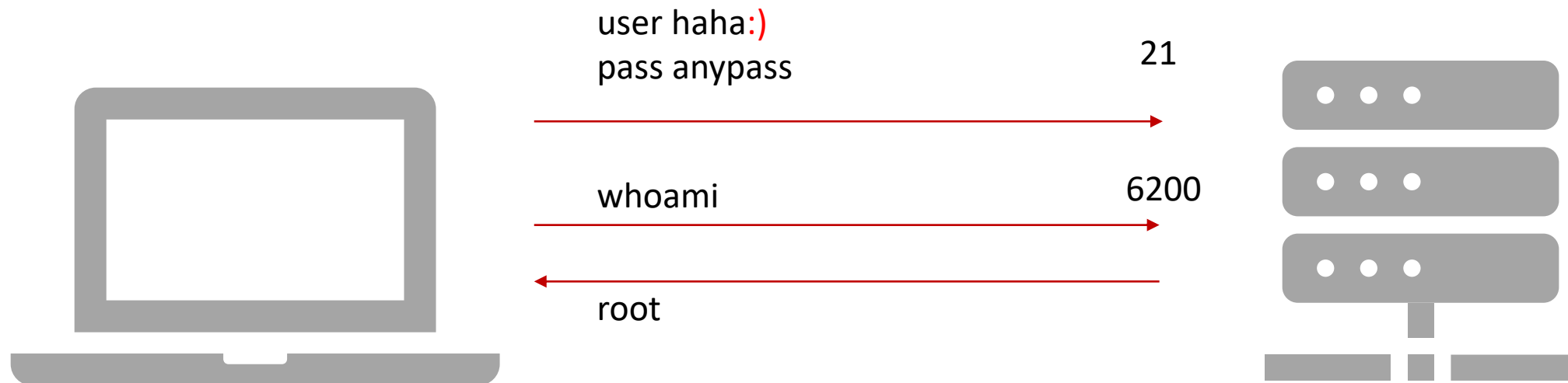
# Check if we could get a version first, then check if it was
# backported
version = get_kb_item_or_exit('www/apache/'+port+'/version', exit_code:1);
backported = get_kb_item_or_exit('www/apache/'+port+'/backported', exit_code:1);

if (report_paranoia < 2 && backported) audit(AUDIT_BACKPORT_SERVICE, port, "Apache");
source = get_kb_item_or_exit('www/apache/'+port+'/source', exit_code:1);

# Check if the version looks like either ServerTokens Major/Minor
# was used
if (version =~ '^2(\.2)?$') exit(1, "The banner from the Apache server listening on port "+port+" - "+source+" - is not granular enough to make a determination.");
if (version !~ '^d+(\.d+)?$') exit(1, "The version of Apache listening on port " + port + " - " + version + " - is non-numeric and, therefore, cannot be used to make a determination.");
if (version =~ '^2(\.2)' && ver_compare(ver:version, fix:'2.2.8') == -1)
{
  set_kb_item(name:"www/"+port+"/XSS", value:TRUE);
  if (report_verbosity > 0)
  {
    report =
    '\n Version source      : ' + source +
    '\n Installed version  : ' + version +
    '\n Fixed version      : 2.2.8\n';
    security_warning(port:port, extra:report);
  }
}
```

CVE-2011-2523

21



Традиционный подход: запуск скрипта для проверки

Example Usage

```
nmap --script ftp-vsftpd-backdoor -p 21 <host>
```

Script Output

```
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2011-2523  BID:48539
|       Description:
|         vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         The backdoor was already triggered
|         Shell command: id
|         Results: uid=0(root) gid=0(root) groups=0(root)
|       References:
|         https://www.securityfocus.com/bid/48539
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234
|_
```



Немного кода на Lua

Проверка наличия уязвимой версии:

```

portrule = function (host, port)
    -- Check if version detection knows what FTP server this is.
    if port.version.product ~= nil and port.version.product ~= "vsftpd" then
        return false
    end

    -- Check if version detection knows what version of FTP server this is.
    if port.version.version ~= nil and port.version.version ~= "2.3.4" then
        return false
    end

    return shortport.port_or_service(21, "ftp")(host, port)
end

```

Проверка активации бэкдора:

```

-- Returns true, results if vsFTPd was backdoored
local function check_backdoor(host, shell_cmd, vuln)
    local socket = nmap.new_socket("tcp")
    socket:set_timeout(10000)

    local status, ret = socket:connect(host, 6200, "tcp")
    if not status then
        return finish_ftp(socket, false, "can't connect to tcp port 6200")
    end

    status, ret = socket:send(CMD_SHELL_ID.."\n")
    if not status then
        return finish_ftp(socket, false, "failed to send shell command")
    end

    status, ret = socket:receive_lines(1)
    if not status then
        return finish_ftp(socket, false,
            string.format("failed to read shell command results: %s",
                ret))
    end

    if not ret:match("uid=") then
        return finish_ftp(socket, false, "service on port 6200 is not the vsFTPd backdoor: NOT VULNERABLE")
    end
end

```

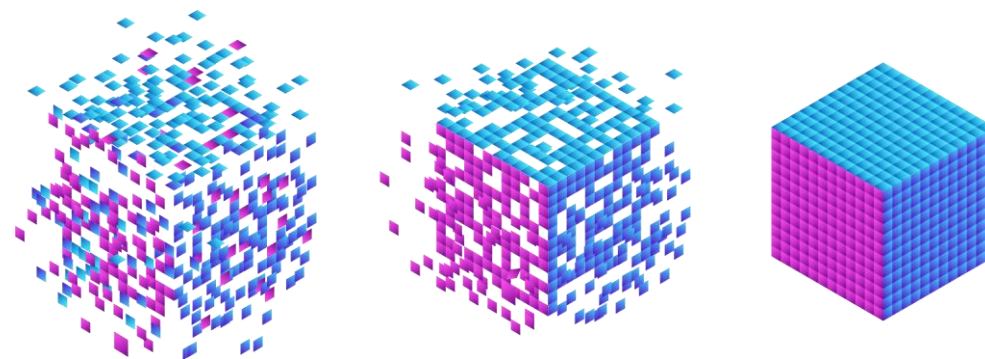
Проблемы традиционного подхода:

- Нужно поддерживать несколько десятков тысяч плагинов/скриптов, выявляющих уязвимости.
- Сканирование одного узла может занимать десятки минут.



Современный подход: использование агрегированной базы данных уязвимостей

- БДУ ФСТЭК России
- NIST National Vulnerability Database
- База обновлений Windows
- RHEL/CentOS Security Data
- Ubuntu CVE Tracker
- Debian GNU/Linux Security Bug Tracker
- ...



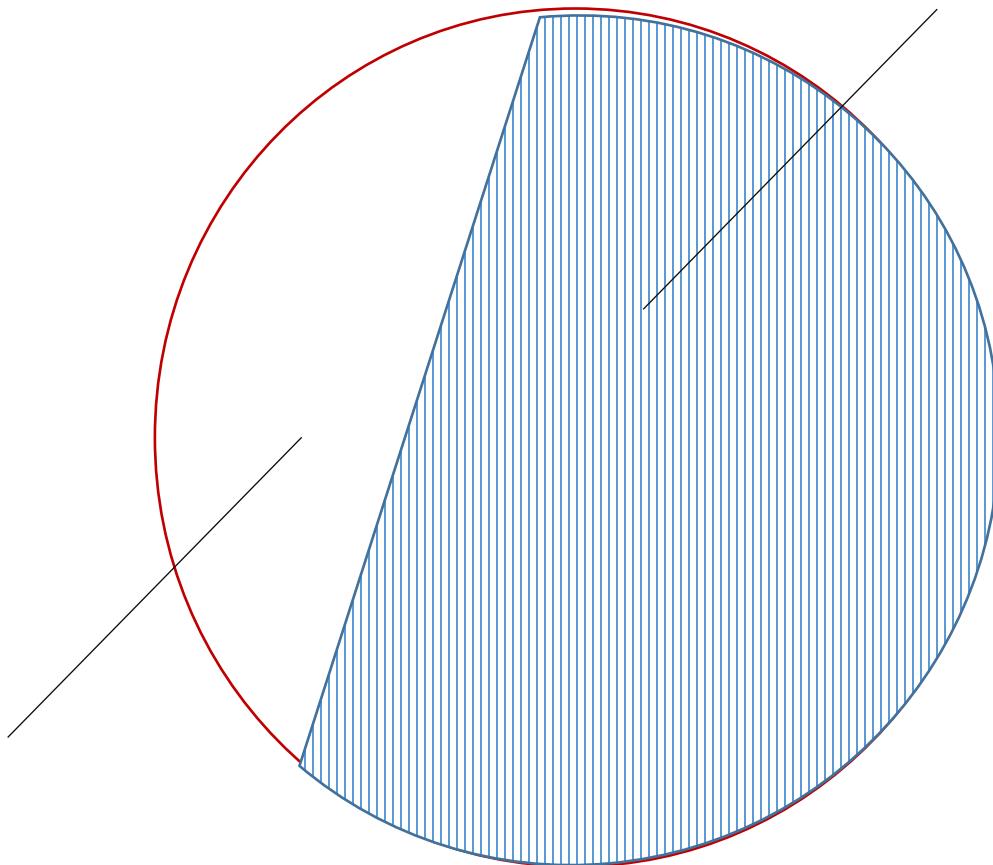
Для полной проверки необходим административный доступ

Все программные пакеты,
включая локальные.

Требуется административный доступ
по SSH/WinRM.



Сетевые сервисы:
требуется только доступ по
сети



Домашнее задание 3

1. Задать Kali Linux 8 GB RAM.
2. Установить в Kali пакеты docker.io и docker-compose.
3. Обновить базу уязвимостей Сканер-ВС 6.
4. Провести сетевое сканирование портов сервера с Tomcat .
5. Провести поиск уязвимостей.
6. Провести инвентаризацию сервера с Tomcat.
7. Провести поиск уязвимостей.

Tomcat: <https://disk.yandex.ru/d/6jt9JNgAh05zcg>

Echelon Eyes

Echelon Eyes



@ECHELONEYES

- Материалы курса: презентации, видео
- Новости об уязвимостях, инцидентах, эксплойтах, изменениях в нормативной базе

**СПАСИБО ЗА
ВНИМАНИЕ!**

Александр Дорофеев
CISSP, CISA, CISM
a.dorofeev@npo-echelon.ru

